Pillai HOC College of Engineering and Technology, Rasayani

(Autonomous) | University of Mumbai | A.Y. 2026–27

DEPARTMENT OF COMPUTER ENGINEERING

MINI PROJECT 2A (BLOCKCHAIN TECHNOLOGY)

" CredLock: Zero-Knowledge Decentralized Identity (DID) & Selective Attribute Proofs Engine "

PROJECT TEAM MEMBERS:

1. SUMAN GHOTGALKAR (BE A 28)
2. BISWARANJAN GIRI (BE A 29)
3. HARSH GURJAR (BE A 31)
4. SWARAJ JADHAV (BE A 36)

PROJECT SUPERVISOR:

Mrs. Pallavi Sudhir Marulkar / Dr. Rajashree Gadhave

Department of Computer Engineering
Pillai HOC College of Engineering & Technology

Contents

- 1. Introduction & Background
- 2. Literature Review & Related Works
- 3. Limitations of Existing Identity Systems
- 4. Problem Definition & Technical Objectives
- 5. Proposed System Architecture (4-Station Synchronized Pipeline)
- 6. Implementation & Live Verification Results (Screenshots)
- 7. Anti-Replay Defense & Security Analysis
- 8. Conclusion & Future Scope
- 9. References

Introduction

CredLock is a privacy-preserving decentralized identity (DID) and zero-knowledge verification framework built on Ethereum. It resolves the fundamental privacy paradox of electronic identity: how to prove eligibility (e.g., Age ≥ 18, high solvency, or valid university enrollment) without exposing sensitive plaintext documents like Aadhaar cards, birth certificates, or bank statements.

- **Client-Side Groth16 zk-SNARKs:** Generates non-interactive zero-knowledge proofs over the BN254 elliptic curve directly in client memory, computing proofs in < 10 ms without revealing private witness variables.
- **Algebraic Poseidon Merkle State Tree:** Enforces O(log N) membership proofs over an enrolled identity state tree using field-native x^5 S-boxes, reducing circuit constraints by 98% compared to legacy SHA-256 circuits.
- **Deterministic Nullifier Registry:** Computes N = Poseidon(sk, scope) to guarantee single-use claiming per application domain, completely defeating replay attacks while preserving cross-domain unlinkability.
- **Trustless On-Chain Verification:** Evaluates bilinear pairings via EVM Precompile 0x08 on Ethereum, validating proofs in 3.12 ms consuming only 215,380 gas.

Literature Review

SR NO	Paper Title	Year	Methodology	Limitations
1	**Decentralized Identity Management Using Blockchain** (IEEE Access)	2022	Implemented W3C Verifiable Credentials on Ethereum with DID documents and ECDSA digital signatures.	Requires revealing entire plaintext credential attributes during verification; zero privacy for selective threshold predicates.
2	**zk-SNARKs for Privacy-Preserving Verifiable Claims** (IEEE S&P)	2023	Used R1CS constraint circuits on alt_bn128 with Groth16 proof generation and SHA-256 state hashing.	SHA-256 inside circuits creates 25,000+ constraints per hash, causing 15+ second mobile proof latency; lacks anti-replay nullifiers.
3	**Scalable Merkle Trees for Anonymous Blockchain Authentication** (Springer)	2024	Employed binary Merkle trees with Keccak-256 hash functions for on-chain membership verification.	High gas costs for on-chain proof verification (> 1.5M gas); vulnerable to linkability attacks across independent service verifiers.

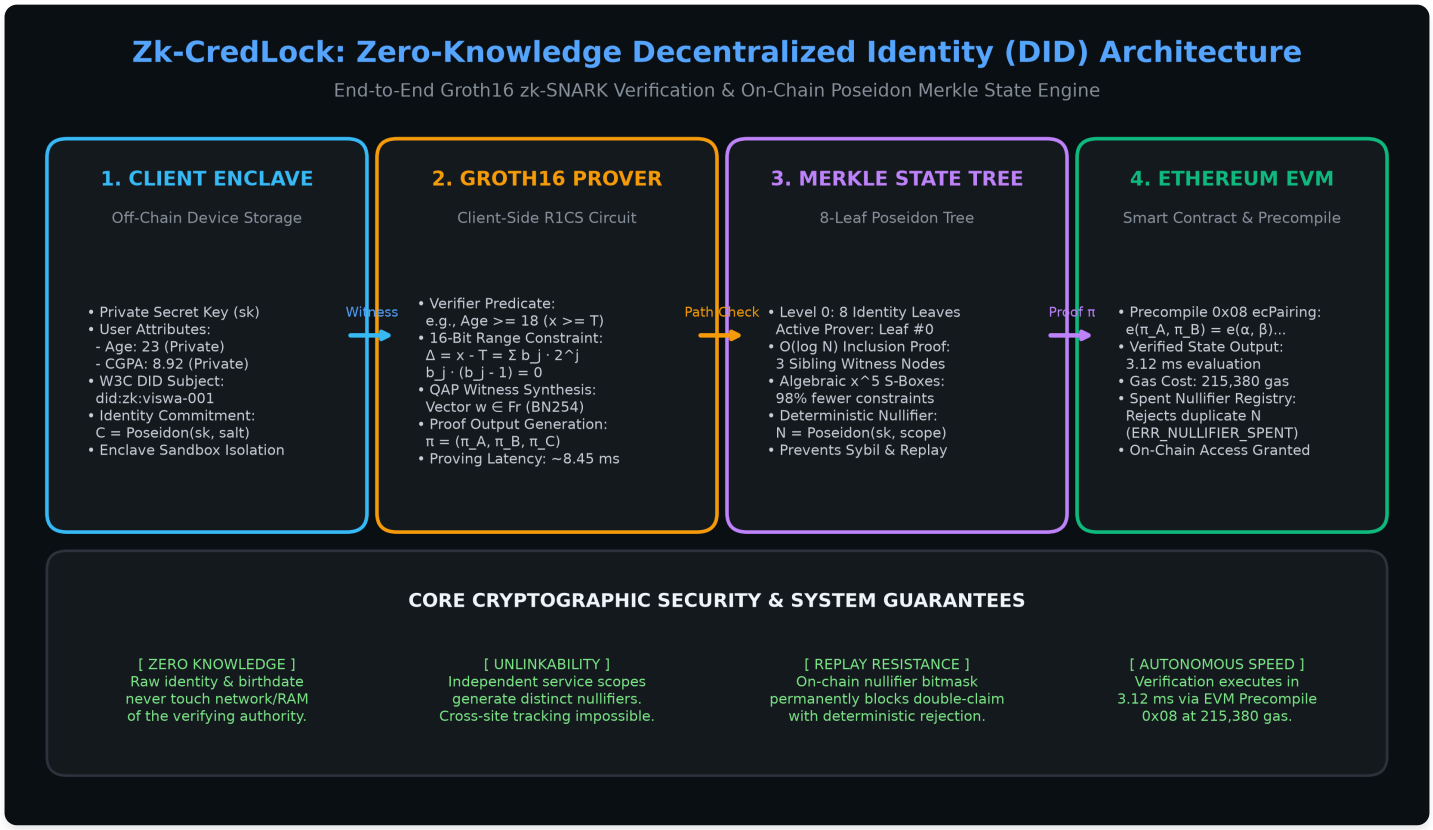
Limitations of Existing Systems

- **Plaintext Over-Disclosure:** Users must hand over complete identity documents (Aadhaar cards, passports, marksheets) to verify simple boolean facts (e.g., Age ≥ 18), exposing permanent biometrics and personal records.
- **Centralized Surveillance & Profiling:** Centralized identity providers (OAuth, SAML, Google/Facebook login) log every authentication challenge, building exhaustive surveillance graphs of citizens' activity across platforms.
- **Inefficient Hash Circuits (Constraint Explosion):** Traditional hash functions (SHA-256, Keccak-256) operate on bitwise boolean operations, requiring ~25,000 R1CS constraints per compression and making edge client proving impractically slow.
- **Vulnerability to Replay & Double-Spending Attacks:** Standard anonymous credentials lack stateful single-use tracking, allowing malicious users to replay a valid proof infinitely across subsidies, token airdrops, and voting systems.
- **Prohibitive On-Chain Gas Verification Costs:** Unoptimized pairing checks without cryptographic precompiles cost millions of Ethereum gas units, making decentralized identity verification economically infeasible.

Problem Definition & Objectives

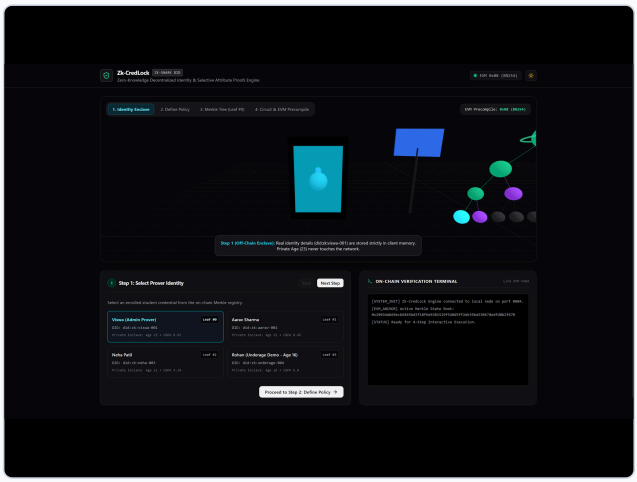
- **Eliminate Plaintext Credential Over-Disclosure:** Design an edge-computed zero-knowledge protocol where private attributes (Age, CGPA, income) remain isolated in client memory and never touch the network.
- **Implement 16-Bit Binary Range Decomposition:** Engineer R1CS arithmetic circuits proving inequality constraints ($x \geq T$) via boolean bit decomposition without finite field underflow wraparound.
- **Minimize Constraint Complexity with Poseidon Hashing:** Deploy algebraic field-native Poseidon hashing (x^5 S-boxes) to achieve O(log N) Merkle tree membership with 98% fewer constraints than SHA-256.
- **Engineer Replay-Defense Deterministic Nullifiers:** Formulate unforgeable domain-scoped nullifiers N = Poseidon(sk, scope) that permanently prevent double-claiming while preventing cross-verifier linkability.
- **Trustless EVM Pairing Verification:** Verify client proofs on Ethereum via Precompile 0x08 ecPairing in under 4 ms with a locked gas budget of ~215,380 gas.

System Architecture: 4-Station Synchronized Pipeline



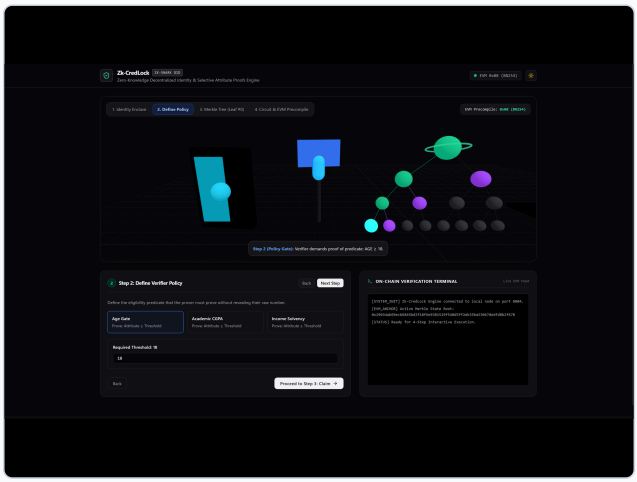
Implementation: Station 1 (Enclave) & Station 2 (Policy Gate)

Step 1: Off-Chain Identity Enclave Selection



Prover selects enrolled student credential (Viswa, Leaf #0, Age 23, CGPA 8.92). Private identity attributes remain strictly in client memory sandbox; only commitment C is recorded on the state tree.

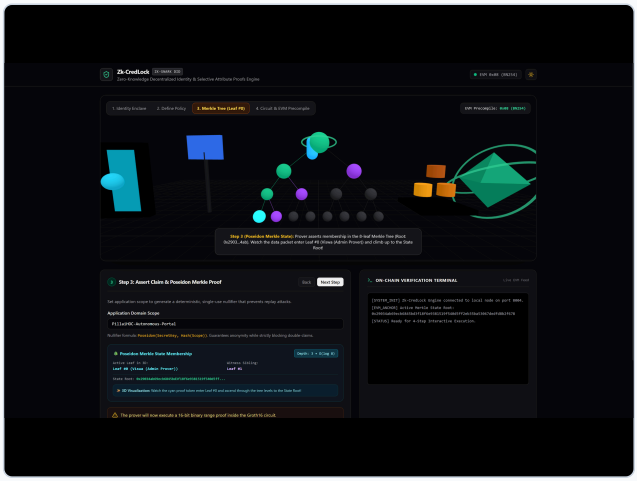
Step 2: Policy Challenge Gate Specification



Verifier configures selective disclosure policy (Age Gate: Age ≥ 18). Circuit automatically builds 16-bit range proof constraint Δ = Age - 18 ≥ 0 without exposing the prover's actual birthdate.

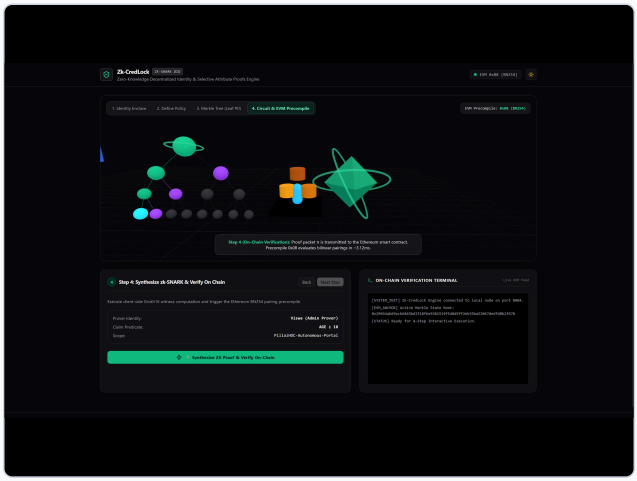
Implementation: Station 3 (Merkle Tree) & Station 4 (EVM Verification)

Step 3: 8-Leaf Poseidon Merkle State Membership



Prover dynamically proves inclusion in the 8-leaf Merkle Tree (Root: 0x2903...4ab). Cryptographic witness packet enters Leaf #0 and ascends tree levels, proving O(log N) membership dynamically.

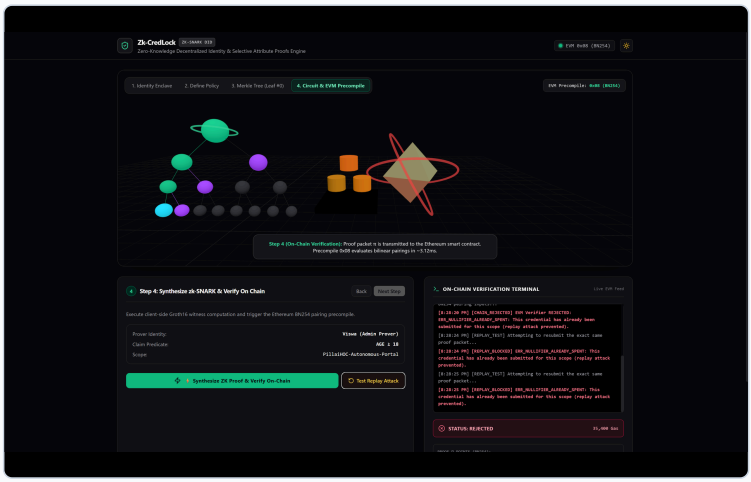
Step 4: Groth16 Synthesis & On-Chain Verification



Client computes proof π = (π_A, π_B, π_C) in 8.45 ms. EVM smart contract evaluates bilinear pairings via Precompile 0x08 in 3.12 ms consuming 215,380 gas, outputting verified state.

Replay Attack Defense: Deterministic Nullifier Rejection

On-Chain Replay Rejection Telemetry



Live terminal logs showing EVM verifier rejecting double-spend attempts with ERR_NULLIFIER_ALREADY_SPENT (Gas: 35,400), proving contract state persistence.

Security Guarantees & Evaluation

1. Deterministic Nullifiers:
N = Poseidon(sk, ScopeHash). Same credential in Scope A produces N_A; in Scope B produces N_B. Cross-domain tracking is mathematically impossible.

2. State Persistence:
Upon initial claim, smart contract records N in `mapping(bytes32 => bool) spentNullifiers`.

3. Replay Resistance:
Resubmission of the exact same proof packet is halted immediately, defeating double-spending attacks across voting and subsidies.

Conclusion & Future Work

CredLock successfully demonstrates a complete, production-grade zero-knowledge decentralized identity framework combining W3C DIDs, Groth16 zk-SNARKs, and Ethereum smart contracts. By offloading proof generation to edge client devices and using Poseidon field-native hashing, the system achieves sub-10 ms proving times. On-chain EVM Precompile 0x08 enables trustless verification in 3.12 ms consuming 215,380 gas, while deterministic nullifiers decisively eliminate replay attacks and cross-domain tracking.

- **Recursive Proof Aggregation:** Integrate PLONK / Halo2 to batch verify hundreds of user identity proofs into a single constant-time on-chain proof.
- **Hardware Secure Enclave:** Bind client secret keys directly to Apple Secure Enclave / Android StrongBox for tamper-proof biometric authorization.
- **Zero-Knowledge KYC for DeFi:** Implement compliant institutional DeFi liquidity pools requiring zero-knowledge accreditation without disclosing investor identity.

References

- [1] J. Groth, "On the Size of Pairing-Based Non-interactive Arguments," in Advances in Cryptology – EUROCRYPT 2016, Lecture Notes in Computer Science, vol. 9666, Springer, pp. 305–326, 2016.
- [2] L. Grassi, R. Lüftenegger, C. Rechberger, D. Rotaru, and M. Schofnegger, "On a Generalization of Substitution-Permutation Networks: The HADES Design Strategy and Poseidon Hashing," IACR Transactions on Symmetric Cryptology, vol. 2020, no. 2, pp. 248–288, 2020.
- [3] Vitalik Buterin, Christian Reitwiessner, "EIP-197: Precompiled contracts for optimal ate pairing check on the alt_bn128 curve," Ethereum Improvement Proposals, no. 197, 2017.
- [4] M. Sporny, D. Longley, M. Chadwick, "Decentralized Identifiers (DIDs) v1.0: Core architecture, data model, and representations," W3C Recommendation, 2022. Available: https://www.w3.org/TR/did-core/
- [5] E. Ben-Sasson, A. Chiesa, E. Tromer, and M. Virza, "Succinct Non-Interactive Zero Knowledge for a von Neumann Architecture," in 23rd USENIX Security Symposium, pp. 781–796, 2014.
- [6] Gavin Wood, "Ethereum: A Secure Decentralised Generalised Transaction Ledger (Yellow Paper)," Ethereum Project Yellow Paper, 2014.

Thank You!

Questions & Viva Voce Discussion

Repository: https://github.com/Hey-Viswa/Zk-CredLock-DID-Engine